

Agent Identity Control Plane

Concept & V0 Product Spec

Last updated: Dec 25, 2025

One-liner

A unified routing + policy enforcement + forensics layer that brings both employee “shadow AI” usage and sanctioned tool-enabled agents under one action-governed control plane: identity, least-privilege, approvals, and incident-grade receipts.

Problem

- **No enforceable boundary:** policies live as docs; they don’t reliably block risky data egress or dangerous tool actions.
- **Identity/intent drift:** an agent may be authenticated, but not continuously constrained to the user’s intent over time.
- **Fragmented controls:** each IDE copilot, agent framework, and runtime has different governance (or none).
- **Poor forensics:** incident response requires reconstructing “who used what model with what data, and what actions occurred”.

V0 scope

The smallest shippable wedge is action-boundary enforcement + receipts for a narrow set of high-risk actions.

In scope

- Policy Decision Point (PDP): allow/deny/allow-with-constraints decisions with rationale + obligations.
- Policy Enforcement Points (PEPs): intercept (a) employee AI traffic via proxy/gateway integration and/or (b) agent tool calls via SDK/proxy wrapper (MCP/HTTP/RPC).
- Credential broker: mint short-lived, scoped credentials for high-risk tools (DB, tickets, cloud, email).
- Receipts ledger: canonical event schema + signed “action receipts” for every blocked/allowed action.
- Admin UX (thin): policy editor (JSON/YAML initially), audit timeline, and exportable evidence bundles.

Out of scope (V0)

- Full “mesh” connectivity/orchestration between agents (that’s a separate bet).
- Deep model-side safety research; assume prompts can be hostile and enforce at tool boundary.
- Multi-tenant SaaS hardening for ultra-regulated environments (start self-hosted or single-tenant).

Architecture

Conceptual layout:

Data plane (enforcement)

- User traffic PEP: forward proxy / secure web gateway integration; optional browser/IDE extension for UX and attribution.
- Agent tool PEP: intercept tool calls before execution (wrapper or HTTP proxy for MCP/HTTP/RPC).
- Credential broker: exchanges long-lived credentials for time-bound, least-privilege tokens tied to intent + policy.

Control plane

- PDP service: evaluates policy against identity + intent + context; returns decision + obligations.
- Policy store: versioned policies; change history; policy-as-code workflow with tests.
- Identity & context: SSO user identity + device identity + workload identity + environment metadata.

Telemetry / IR plane

- Canonical event schema across prompts/uploads and tool calls.
- Receipt signing + storage; search and correlation by user/agent/tool/resource.
- Evidence bundles: export incident timeline + artifacts needed for postmortems or legal/compliance.

Key product decisions

- Enforce on **actions**, not “prompts”. Prompts are untrusted input; tool execution is the trust boundary.
- Start with a small number of tool connectors (GitHub/Jira/Slack/SQL/cloud) and a small number of policies that matter.
- Optimize for a demo where a prompt injection attempt results in a blocked action with a clear receipt and rationale.

Success criteria for V0

- Integrates into at least one real workflow (developer + agent tooling) and blocks a meaningful class of risky actions.
- Produces receipts that answer: *who/what/when/why allowed* + what constraints were applied.
- Policies are testable and changes are auditable (policy-as-code path works).
- A buyer can understand the wedge in under 60 seconds: “identity + policy at the action boundary for agents and shadow AI.”